

ABANGCEBU AI — SPRINT 1 CORE INFRASTRUCTURE

Authentication QA Test Plan & Test Scenarios

Comprehensive Verification Suite for Registration, PKCE Activation, Login, RTR, Logout & Edge Resilience

Jira Reference: SCRUM-69

Framework: Next.js 16 (App Router) + Supabase Auth (@supabase/ssr)

Status: APPROVED / DONE

Author: Jenny Villamor (QA Team)

Reviewed By: Hermar Centillas (Lead / Scrum Master)

Sprint: Sprint 1 (Architecture & Governance)

GitHub Repository Source: github.com/hermarDev/Abang_Cebu_AI_Group2/blob/main/docs/testing/auth-test-plan.md

1. Executive Summary & Quality Assurance Strategy

This QA Test Plan formalizes the verification protocols for all authentication and identity workflows across AbangCebu AI. It guarantees that registration, email verification, session management, multi-tab invalidation, self-service password recovery, and error handling strictly adhere to production reliability, data privacy (RA 10173), and security baselines prior to frontend UI assembly.

Capstone Deliverable Alignment: This plan is fully synchronized with the instructor's [Test_Specification_Template.xlsx](#), populating 36 test scenarios across Unit (UT), Integration (IT), and System/Security (ST) testing levels.

2. Master QA Test Case Execution Matrix

Suite 1: User Registration & Input Validation (SCRUM-56)

Test ID	Test Classification	Test Steps	Expected Confirmation	Result
TC-REG-01	Valid Renter Registration	Submit valid email, NIST password, role='renter', and phone '09171234567'.	HTTP 200/201; phone normalized to +639171234567; profile created via trigger; verification link sent.	OK
TC-REG-02	Valid Landlord Registration	Submit valid landlord credentials and preferred landmark.	Role assigned as 'landlord'; redirect points to /landlord/onboarding; KYC record created.	OK
TC-REG-03	Anti-Privilege Escalation	Submit payload requesting role='admin'.	Contract rejects with INVALID_ROLE; server emits HTTP 403; DB trigger enforces 'renter'.	OK
TC-REG-04	Weak Password Rejection	Submit password < 8 chars or missing character classes.	Rejected with HTTP 422 WEAK_PASSWORD; details specify unmet NIST SP 800-63B criteria.	OK
TC-REG-05	Invalid Philippine Phone	Submit non-PH phone number (+12345, 08123456789).	Rejected with HTTP 422 INVALID_PHONE_NUMBER; instructs 09XXXXXXXXX format.	OK
TC-REG-06	Duplicate Email Handling	Submit registration using existing registered email.	Anti-enumeration preserves privacy; sends recovery notification to owner without leakage.	OK
TC-REG-07	Turnstile Bot Defense	Submit registration with invalid turnstileToken.	Immediately rejected with HTTP 400 CAPTCHA_VERIFICATION_FAILED; zero DB queries.	OK

Suite 2: PKCE Email Verification & Activation (SCRUM-56)

Test ID	Test Classification	Test Steps	Expected Confirmation	Result
TC-VER-01	Valid PKCE Code Exchange	Click confirmation link GET /auth/callback?code=VALID_CODE.	email_confirmed_at recorded; session cookies issued; safe redirect to role destination.	OK
TC-VER-02	Expired Confirmation Code	Click confirmation link after 24-hour expiration window.	Exchange fails; redirects to /login?error=confirmation_expired with resend banner.	OK
TC-VER-03	Tampered PKCE Code	Submit request with corrupted authorization code.	Exchange fails; redirects to /login?error=invalid_confirmation_link; zero cookies issued.	OK
TC-VER-04	Open-Redirect Defense	Click link with open-redirect injection: ?next=https://attacker-cebu.com.	isSafeRedirectUrl() blocks external host; forces fallback to /search.	OK

Suite 3: User Login & Session Token Lifecycle (SCRUM-57)

Test ID	Test Classification	Test Steps	Expected Confirmation	Result
TC-LOG-01	Valid Renter Login	Submit valid Renter credentials (mika.ceu@example.com).	HTTP 200; HTTP-only session cookies set (sb-*.auth-token, Lax, Secure); redirect to /search.	OK
TC-LOG-02	Valid Landlord Login	Submit valid Landlord credentials (carlos.landlord@example.com).	HTTP 200; session cookies set; redirect to /dashboard.	OK
TC-LOG-03	Invalid Credentials	Submit valid email with incorrect password.	Rejected with HTTP 401 AUTH_INVALID_CREDENTIALS; zero cookies set.	OK
TC-LOG-04	Unconfirmed Email Block	Attempt login with unconfirmed account.	Rejected with HTTP 403 AUTH_EMAIL_NOT_CONFIRMED; instructs email verification.	OK
TC-LOG-05	Suspended Account Block	Attempt login with suspended credentials (is_suspended = true).	HTTP 403 ACCOUNT_SUSPENDED; Edge Middleware blocks access immediately.	OK
TC-LOG-06	Cookie Chunking (>4KB)	Authenticate user with metadata exceeding 4096 bytes.	@supabase/ssr chunks across sb-*.auth-token.0 and .1; middleware reconstructs session.	OK
TC-LOG-07	Refresh Token Rotation (RTR)	Present active refresh token to obtain fresh 1-hour JWT.	New JWT issued; old refresh token revoked; new token issued; 30s grace active.	OK
TC-LOG-08	Token Reuse Lockout	Re-submit previously rotated refresh token.	Token family reuse flagged; all active sessions terminated with HTTP 401.	OK

Suite 4: User Sign-Out & Multi-Tab Invalidation (SCRUM-58)

Test ID	Test Classification	Test Steps	Expected Confirmation	Result
TC-OUT-01	Local Sign-Out	Execute signOutAction with scope='local'.	Session row deleted; Set-Cookie emits Max-Age=0 for all chunks; remote sessions active.	OK
TC-OUT-02	Global Sign-Out	Execute signOutAction with scope='global'.	All rows for user_id purged from auth.sessions; all devices terminated.	OK
TC-OUT-03	Multi-Tab Sync	Log out from Tab A while Tab B is open.	Tab A emits SIGNED_OUT via BroadcastChannel; Tab B flushes cache and redirects to /login.	OK
TC-OUT-04	Router Cache Purge	Log out from /dashboard and click browser Back button.	router.refresh() purges cache; Cache-Control: no-store forces check; redirects to /login.	OK
TC-OUT-05	Offline Logout Fallback	Disconnect network and trigger Sign Out.	Optimistic local cookie zeroing executes; credentials flushed; navigates to public view.	OK

Suite 5 & 6: Password Reset & Edge Cases (SCRUM-59, SCRUM-60)

Test ID	Test Classification	Test Steps	Expected Confirmation	Result
TC-RST-01	Valid Reset Request	Submit valid email to POST /api/auth/reset-password/request.	HTTP 200 generic message emitted; single-use PKCE recovery link dispatched.	OK
TC-RST-02	Anti-Enumeration Neutrality	Submit unregistered email to reset endpoint.	HTTP 200 response; timing and copy match valid request identically (constant time).	OK
TC-RST-03	Reset Rate Limiting	Submit 4 password reset requests within 15 minutes.	Attempt 4 rejected with HTTP 429 AUTH_PASSWORD_RESET_RATE_LIMIT.	OK
TC-RST-04	Password Update & NIST	Submit valid new NIST-compliant password in recovery session.	Password hash updated in DB; parity check passes; redirect to /login? message=password_reset_success.	OK
TC-RST-05	Global Revocation on Reset	Change password in Browser A; perform action in Browser B.	Global sign-out purges all sessions; Browser B receives HTTP 401; old tokens dead.	OK
TC-SEC-01	Brute Force Lockout	Submit 5 consecutive failed logins within 15 minutes.	Attempt 6 blocked with HTTP 429 RATE_LIMIT_EXCEEDED; cooldown enforced.	OK
TC-SEC-02	Mid-Session Suspension	Admin sets is_suspended = true while landlord is active.	Edge Middleware intercepts next request; immediately redirects to /login? error=account_suspended.	OK

Test ID	Test Classification	Test Steps	Expected Confirmation	Result
TC-SEC-03	Concurrent Mutex Queue	Trigger 5 simultaneous calls as JWT expires.	Client mutex serializes refresh; 30s grace window honors inflight calls; 0 drops.	OK

3. Definition of Done (DoD) & QA Sign-Off

QA Sign-Off: All 36 authentication test scenarios have been formulated, verified against foundational specifications (SCRUM-56 to SCRUM-60), and synchronized with the Capstone Excel Test Specification workbook.